UE : SUPERVISION, ANALYSE FORENSIQUE ET GESTION DES INCIDENTS

TRAVAUX PRATIQUE I

Ex. 1.1 — Diagnostic de maturité. Appliquez la grille (tab. 1.3) à LiZbiZ-SIS.

Niveau 1

Justification : Le SOC n'a aucune visibilité structurée. Sans SIEM ni collecte centralisée des logs, la détection dépend entièrement des signalements utilisateurs. Le MTTD > 7 jours signifie qu'une attaque peut persister plus d'une semaine sans être détectée, exposant l'organisation à des dommages critiques (exfiltration, ransomware, pivoting).

correctives prioritaires :

- Déployer un SIEM de base (ex. Elastic SIEM, Microsoft Sentinel) avec collecte des logs AD, firewall et endpoints
- Définir un processus minimal de gestion des incidents avec des niveaux de sévérité et une astreinte d'escalade

Niveau 2

Justification : Le SIEM est en place mais les règles par défaut génèrent un volume d'alertes non triées, provoquant de la fatigue d'alerte. Les analystes passent leur temps à trier manuellement, ce qui maintient le MTTD entre 2 et 7 jours et masque les incidents réels dans le bruit.

correctives prioritaires :

- Implémenter un système de ticketing et de triage (ex. TheHive) avec priorisation automatique par criticité actif/vulnérabilité
- Affiner et contextualiser les règles de détection en désactivant les règles à fort taux de faux positifs et en les adaptant au contexte métier

Niveau 3

Justification : Les règles sont personnalisées et le triage est opérationnel (FPR < 50 %), mais la détection reste réactive. Le SOC répond aux alertes sans anticiper les menaces. Le MTTD < 24 h est acceptable mais insuffisant face aux attaques modernes dont le temps de déplacement latéral peut être inférieur à quelques heures.

correctives prioritaires :

- Intégrer une source de Cyber Threat Intelligence (CTI) pour enrichir les alertes avec des IOCs et TTPs connus (MITRE ATT&CK)
- Mettre en place des métriques SOC formelles (MTTD, MTTR, taux de faux positifs) pour piloter l'amélioration continue

Niveau 4

UE : SUPERVISION, ANALYSE FORENSIQUE ET GESTION DES INCIDENTS

Justification : Le threat hunting proactif et la CTI intégrée permettent d'atteindre un FPR < 30 % et un MTTD < 4 h. Cependant, les processus de réponse restent majoritairement manuels, ce qui crée un goulot d'étranglement humain à grande échelle et limite la capacité à traiter des volumes d'incidents élevés.

Actions correctives prioritaires :

- Déployer une plateforme SOAR (ex. Splunk SOAR, Palo Alto XSOAR) pour automatiser les playbooks de réponse sur les incidents récurrents
- Structurer un programme de threat hunting récurrent avec des hypothèses documentées basées sur les campagnes actives (OSINT, ISACs sectoriels)

Niveau 5

Justification : C'est le niveau d'excellence opérationnelle. Le SOAR, le ML et l'automatisation permettent une détection prédictive avec un MTTD < 1 h. Le risque à ce stade est la dépendance technologique et la dérive des modèles ML sur de nouvelles menaces, ainsi que la difficulté à maintenir les compétences humaines face à l'automatisation croissante.

Actions correctives prioritaires :

- Mettre en place un programme de red team/purple team continu pour valider en permanence l'efficacité des détections et éviter l'effet « fausse sécurité »
- Gouverner et auditer les modèles ML (drift detection, biais, réentraînement régulier) pour garantir leur pertinence face à l'évolution des TTPs adversaires

EX 1.2 : LiZbiZ-SIS dispose de : 1 firewall pfSense, 2 serveurs Windows (AD + ERP), 1 serveur Linux Apache, 1 MySQL, 30 postes Windows, 1 proxy Squid. Priorisez les 5 sources à intégrer en premier au SIEM en justifiant par les menaces détectables

1- serveur Windows (AD): nous avons les menaces suivantes

- Brute force / password spraying
- Escalade de privilèges (admin)
- Création de comptes suspects
- Mouvement latéral
- Attaques type Kerberoasting

2. Firewall pfSense

Menaces détectables :

- Scans de ports

- Tentatives d'intrusion externes
- Connexions vers IP malveillantes
- Activité anormale VPN
- Exfiltration de données

3. Serveur Web Apache (Linux)

Menaces détectables :

- SQL Injection
- Remote Code Execution (RCE)
- Scan de vulnérabilités
- Webshells
- Tentatives d'accès admin

4. Proxy Squid

Menaces détectables :

- Accès à sites malveillants (C2)
- Phishing
- Téléchargement de malware
- Exfiltration via HTTP/HTTPS
- Comportement anormal utilisateur

5. Serveur ERP (Windows)

Menaces détectables :

- Accès anormal (horaires, localisation)
- Abus de privilèges
- Extraction massive de données
- Manipulation de transactions

Ex1.3 :

syntaxe SIGMA

```
<group name="sysmon">

  <rule id="100001" level="10">

    <decoded_as>json</decoded_as>
```

```
    <description>Détection d'un mouvement latéral via SMB (T1021.002) : Connexion SMB réussie depuis un poste utilisateur vers plus de 3 serveurs distincts en moins de 5 minutes.</description>

    <group>authentication-success, network-activity</group>

    <mitre>

      <technique>T1021.002</technique>

      <tactic>lateral-movement</tactic>

    </mitre>

    <criteria>

      <field name="event.code">5156</field>

      <field name="source_ip">!127.0.0.1</field>

      <field name="destination_port">445</field>

      <field name="user.name">*utilisateur*</field>

      <timeframe>300</timeframe> <!-- 300 secondes = 5 minutes -->

      <aggregate>

        <field name="destination_ip">count</field>

        <condition>gt</condition>

        <value>3</value>

      </aggregate>

    </criteria>

  </rule>

</group>
```

Niveau de gravité (`level="10"`) : Niveau élevé (selon Wazuh, 10 est un niveau de gravité élevé).

Mapping MITRE :

- **Tactic** : `lateral-movement`
- **Technique** : `T1021.002` (Mouvement latéral via SMB)

UE : SUPERVISION, ANALYSE FORENSIQUE ET GESTION DES INCIDENTS

TRAVAUX PRATIQUE II

EX 2.2. : Configuration Rsyslog. Rédigez /etc/rsyslog.d/50-siem.conf pour qu'un Ubuntu 22.04 expédie vers le SIEM (10.0.0.5:6514 TCP TLS) tous les journaux de niveau warning et supérieur, avec file d'attente persistante de 10 000 messages.

```
# Chargement des modules nécessaires
module(load="imuxsock")   # logs locaux
module(load="imklog")     # logs kernel
module(load="omfwd")      # forwarding
module(load="gtls")       # TLS

# Paramètres globaux TLS (adapter les chemins aux certificats)
global(
  DefaultNetstreamDriver="gtls"
  DefaultNetstreamDriverCAFile="/etc/rsyslog.d/ca.pem"
  DefaultNetstreamDriverCertFile="/etc/rsyslog.d/client-cert.pem"
  DefaultNetstreamDriverKeyFile="/etc/rsyslog.d/client-key.pem"
)

# Template (format classique RFC5424)
template(name="SIEMFormat" type="string"
        string="<%PRI%>1 %TIMESTAMP:::date-rfc3339% %HOSTNAME% %app-name% %procid% - - %msg%\n")

# Règle d'envoi vers le SIEM (warning et plus critique)
if ($syslogseverity <= 4) then {
  action(
    type="omfwd"
    target="10.0.0.5"
    port="6514"
```

```
    protocol="tcp"
    StreamDriver="gtls"
    StreamDriverMode="1"        # TLS only
    StreamDriverAuthMode="x509/name"
    StreamDriverPermittedPeers="10.0.0.5"

    Template="SIEMFormat"

    # File d'attente persistante
    queue.type="LinkedList"
    queue.filename="siem_queue"
    queue.maxdiskspace="100m"
    queue.size="10000"
    queue.saveonshutdown="on"
    queue.highwatermark="8000"
    queue.lowwatermark="2000"
    queue.discardmark="9500"
    queue.discardseverity="0"
  )
}
```

EX 2.3

(a) Durée entre le premier scan et la première connexion réussie

- Scan initial : **02:47:11**
- Authentification réussie : **03:14:51**

Durée : 27 minutes et 40 secondes

(b) EID confirmant l'effacement des journaux

- **EID 1102**

Correspond à **l'effacement du journal de sécurité Windows**

(c) Technique MITRE du mouvement latéral

- **T1021.002 — SMB/Windows Admin Shares**

Mouvement latéral via SMB

(d) Deux mesures qui auraient interrompu l'attaque dès l'étape 3 (accès réussi)

1. **Désactivation de l'authentification par mot de passe SSH**
    - Utilisation exclusive de **clés SSH**
    - Empêche le succès du brute force
2. **MFA (authentification multi-facteurs) sur SSH**
    - Même avec mot de passe compromis → accès bloqué